

Informática

Estudio de caso: banca electrónica

Para usar en mayo de 2015 y noviembre de 2015

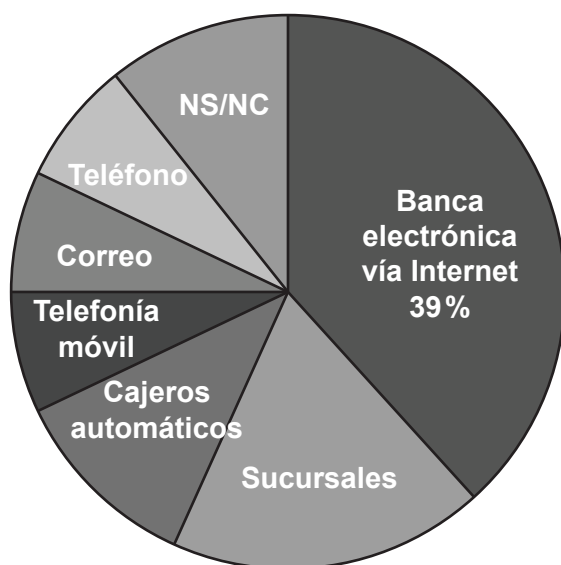
Instrucciones para los alumnos

- Para la prueba 3 del nivel superior se requiere el cuadernillo del estudio de caso.

Introducción

La banca moderna, tal como la conocemos hoy en día, se inició en Italia, en el siglo XIV, cuando los agricultores pedían prestado dinero para financiar la siembra de sus cosechas mientras que el valor de las mismas se tomaba como garantía de los préstamos. Las personas que otorgaban esos créditos realizaban sus negocios en los bancos de los mercados agrícolas. La palabra “banca” proviene del italiano *banca*, que significa “banco”, un asiento rústico y alargado. Por toda Europa se difundieron prácticas bancarias similares a medida que los bancos se desplazaban a establecimientos más permanentes, y desde entonces se han convertido en el pilar fundamental de las transacciones financieras, inicialmente entre empresas y posteriormente entre individuos.

Método preferido de acceso a banca en 2013, EEUU



Los últimos veinte años han sido testigos de un cambio espectacular en la forma en que los bancos interactúan con sus clientes, con la llegada de la banca en línea posibilitada por el desarrollo de Internet.

Como consecuencia, los bancos están migrando gradualmente sus transacciones desde el mundo físico de las sucursales en zonas urbanas al mundo virtual¹. Las innovaciones tecnológicas han revolucionado la industria bancaria con transacciones que hoy se realizan casi instantáneamente desde cualquier lugar del mundo que disponga de una conexión a Internet.

Las ventajas de costo para los bancos y la comodidad para los clientes son claras, aunque hay algunos inconvenientes. La seguridad y la autenticidad son las piedras angulares de todas las transacciones financieras y todo el sistema bancario depende de la transmisión segura de datos. Según informó el periódico *The Guardian* en septiembre de 2013, los estándares de encriptación usados para esas transacciones podrían no ser ya seguros y representan, por tanto, un gran motivo de preocupación².

En estos últimos años se han visto más cambios, dirigidos hacia la realización de transacciones bancarias y pagos desde dispositivos móviles, debido al aumento del número de usuarios de smartphones y tabletas. Los clientes que usan estos dispositivos esperan que sus servicios bancarios estén disponibles cuando se desplazan y exigen tanto seguridad como facilidad de uso, un equilibrio difícil de conseguir para el personal que trabaja en el departamento tecnológico de los bancos.

Este estudio de caso analiza las operaciones del banco ficticio *TransEuropa*. Se centra en la informática que subyace tanto las operaciones como los aspectos de seguridad de las transacciones bancarias.

¹ <http://www.aba.com>

² <http://www.theguardian.com/.../nsa-gchq-encryption-codes-security>

TransEuropa

TransEuropa tiene su casa matriz en un país europeo en el que se estableció hace muchos años. También está presente en algunos países en desarrollo donde cuenta con sucursales en las ciudades más importantes.

En una entrevista, Michael – jefe de operaciones tecnológicas – explicó como la seguridad es la máxima prioridad en sus operaciones bancarias. También describió algunos de los procedimientos actualmente en uso.

“Incluso aunque nuestras operaciones bancarias en Internet se han realizado por varios años en Europa, seguimos teniendo que tratar cuestiones de seguridad relacionadas con nuestras operaciones. Para que los clientes confíen en nuestra compañía, es fundamental que estén completamente seguros de que la posibilidad de que un fraude ocurra es mínima.

Dos de las áreas principales de atención son la autenticación y la transmisión segura de datos. Nuestro proceso de inicio de sesión se basaba antes en la introducción de un nombre de usuario y una contraseña, pero esto se ha cambiado por una autenticación 2-factor. Ahora el cliente responde a una pregunta de seguridad y posteriormente introduce un número de autenticación de transacción (TAN), que es un tipo de contraseña de un solo uso. Cada uno de los clientes que operan en línea recibe un teclado especial que permite generar el TAN después de introducir un código que sólo conocen el propio usuario y el banco. De esta forma el usuario puede continuar con la transacción o la consulta sólo después de responder a la pregunta de seguridad y después de que el servidor del banco haya verificado el TAN.”

Michael continuó hablando sobre la seguridad en las transmisiones. Explicó que, como las operaciones en línea se realizan a través de Internet, la seguridad se sostiene sobre el protocolo SSL, que usa tanto encriptación asimétrica como simétrica. Un certificado digital de validación extendida emitido por una agencia de certificación se envía desde el servidor del banco al computador del cliente.

Desarrollos recientes sugieren que esta encriptación se puede romper, lo cual tiene mucha importancia para cualquier empresa que desee realizar transmisiones de datos seguras. Michael se preguntaba si la longitud actual de 2048 bits de la clave de encriptación podría romperse mediante métodos de descryptación por fuerza bruta o si algunas agencias habían usado métodos de puerta trasera para descryptar las transmisiones³. De cualquier forma, dijo, es necesario revisar constantemente los procedimientos de seguridad del banco.

La amenaza del software malicioso también es una preocupación constante para el sector bancario. Michael señaló vulnerabilidades de seguridad como el *phishing* y el troyano MitB como peligros concretos que los clientes deben conocer. Sugirió que el banco debiera considerar medidas adicionales, como la verificación externa, para minimizar los riesgos que representan esas amenazas.

³ <http://www.computerweekly.com/news/.../US-acts-to-restore-...>

Banca móvil

La banca electrónica vía Internet estaba restringida inicialmente a los computadores personales, pero el auge de la tecnología móvil y la posibilidad de acceder a Internet desde smartphones y tabletas han hecho que aumente la demanda de banca móvil.

Este aumento se demuestra en la estadística siguiente, tomada de la edición del año 2013 del evento *Annual Mobile Banking and Commerce Summit* (Cumbre anual del comercio y la banca móviles)⁴:

- Este año, a nivel global, 590 millones de usuarios de telefonía móvil emplearán su dispositivo para realizar operaciones bancarias. En 2017, ese número superará los mil millones.
- A nivel mundial, los bancos gastarían USD118 mil millones en tecnología y banca móvil en 2013.
- Actualmente en EEUU, 81 de las 100 principales instituciones financieras ofrecen algún tipo de banca móvil.

TransEuropa ya ha seleccionado dos enfoques diferentes para esta área. Cuando se le preguntó por el tema, Michael explicó que la propuesta para los países en desarrollo diferiría de la empleada en Europa, debido a las diferencias en cuanto a la tecnología de que disponen los clientes de una y otras zonas. Y prosiguió:

“En Europa queremos ofrecer a nuestros clientes de telefonía móvil la misma variedad de servicios de que disponen los usuarios de computadores personales. No obstante, los dispositivos móviles tienen una gran variedad de formas, tamaños y especificaciones, así que necesitamos personalizar el contenido para cada dispositivo. Con ese fin, usamos tecnología de detección de dispositivos móviles para las solicitudes HTTP que llegan a nuestros servidores. Esta detección se basa en leer el campo de agente del usuario de la cabecera del HTTP y correlacionar los datos almacenados en ese campo con los distintos modelos descritos en los repositorios de descripción de dispositivos (*Device Description Repository*). Ofrecemos una combinación de tecnologías *push* y *pull* e intentamos convencer a nuestros clientes que descarguen aplicaciones específicas para sus dispositivos móviles (conocidas como Apps). También ofrecemos ciertos servicios de banca a través de mensajes SMS.”

A continuación explicó como el nivel de seguridad de las transmisiones móviles varía en función del tipo de conexión.

“Los clientes pueden estar usando WiFi, donde la conexión podría estar controlada por los protocolos WPA o WEP, o usar un servicio no seguro. Si estuvieran conectados a través de su compañía telefónica estarían usando protocolos GSM.”

⁴ <https://blog.compete.com/.../mobile-banking-today-highlights-from-mcs2013/>

Continuó explicando que a la banca móvil en los países en desarrollo se le dio un enfoque totalmente distinto.

“Nuestra base de clientes en Europa es absolutamente diferente de la de los países en desarrollo. En Europa, la mayoría de nuestros clientes están conectados a Internet y necesitan facilidades de banca electrónica. Esperan poder realizar todas sus operaciones financieras en línea. Estos datos se pueden contrastar con los países en desarrollo, en los que las operaciones se limitan a las ciudades y donde la mayoría de clientes aún siguen yendo físicamente al banco para gestionar sus negocios. La mayoría de la población rural no tiene acceso a Internet. De hecho, la mayoría no tiene una cuenta bancaria. En cambio, casi todos poseen teléfonos móviles.”

Luego pasó a explicar como *TransEuropa* se ha asociado con una compañía local de telecomunicaciones en uno de los países en desarrollo para ofrecer servicios financieros básicos a la población rural, incluso a usuarios que no tienen cuentas bancarias. Han basado sus operaciones en el éxito que ha tenido el sistema M-PESA en Kenia, donde los propietarios de teléfonos móviles pueden realizar ciertos pagos, como recibos de servicios públicos, o transferir dinero a otras personas, incluso entre países. Se puede añadir crédito a cada teléfono (o recibir dinero) desde cualquiera de las oficinas de los operadores móviles que se encuentran en todo el país.

“La gente puede usar el crédito en el teléfono móvil como si fuera una cuenta bancaria móvil”, explicó Michael. “Funciona porque la mayoría de la población adulta tiene teléfonos móviles que pueden enviar mensajes SMS. Parte de nuestra función es desarrollar el STK (*SIM Application Toolkit*), que ofrece una interfaz con el usuario.”

Nuevos desarrollos

El primero fue el desarrollo de una aplicación de Billetera Móvil que los clientes del banco pueden descargar en sus smartphones. Esta aplicación les permite usar sus smartphones para pagar compras con tarjetas de tiendas o con tarjetas de crédito o débito en tiendas que cuentan con la tecnología necesaria. Michael mencionó *Starbucks* como una cadena en la que un porcentaje significativo de las ventas se realiza de esta forma, y a *Pingit* y *Zapp* como dos servicios de pago móvil que ya operan con otras compañías. La misma aplicación móvil permite que los clientes accedan a los cajeros automáticos sin que para ello deban contar con una tarjeta bancaria.

“Esta idea de Billetera Móvil es la que esperamos que nuestros clientes adopten finalmente, ya la gente busca formas cada vez más rápidas y fáciles de realizar las compras. Creemos que es un mercado en el que debemos entrar, pues los clientes tienden a confiar más en la tecnología cuando la ofrecen los bancos. Las opciones disponibles son usar la tecnología ‘sin contactos’ mediante NFC o los códigos QR como parte del proceso de pago. En ambos casos la salvaguarda de la información sensible es una prioridad.”

Michael señaló que, según *Visa Europe*, en 2020 más de la mitad de sus transacciones se realizarán desde un dispositivo móvil⁵.

⁵ <http://www.bankingtech.com/...-payments-play-with-first-data/...>

El segundo desarrollo consiste en investigar el uso de la biometría para ofrecer una autenticación y una verificación más seguras. La biometría se usó durante algún tiempo como un componente de la autenticación multi-factor en áreas como la inmigración, pero por distintos motivos su incorporación a los servicios bancarios ha sido más lenta.

Michael concluyó resumiendo los problemas principales de la banca moderna desde el punto de vista tecnológico con la mirada puesta en el futuro.

“Las áreas principales que resultan claves para mantener y aumentar nuestra base de clientes son la autenticación, la seguridad de los datos y la interfaz de usuario. Respecto de la autenticación, iremos orientándonos hacia la biometría cada vez más. Para garantizar la seguridad de los datos debemos controlar continuamente los estándares de encriptación que se usan en Internet (SSL/TLS) y en las transmisiones móviles (protocolos WiFi y GSM). Aunque deberemos mantener algunos de los servicios tradicionales, la mayoría de nuestros clientes pide cada vez más que los servicios como la banca electrónica vía Internet y los pagos vía móviles sean parte integral de la vida cotidiana donde la calidad del servicio suele ser más importante que el proveedor. Si vamos a sobrevivir debemos adaptarnos a un escenario siempre cambiante.”

Retos afrontados

Los retos que Michael y *TransEuropa* afrontarán en un futuro inmediato son:

- preparar un informe sobre los distintos protocolos de encriptación que se usan actualmente y cómo podrían cambiar en el futuro;
- diseñar la interfaz de usuario que operará con el STK para su proyecto de banca móvil para los países en desarrollo;
- finalizar la investigación necesaria para desarrollar el proyecto de Billetera Móvil;
- revisar los procedimientos de autenticación para aumentar la seguridad de las operaciones bancarias.

Terminología adicional a la de la guía

Aplicaciones para dispositivos móviles (Apps)
Autenticación / 2-factor / autenticación multi-factor
Billetera Móvil (*Mobile Wallet*)
Campo de agente del usuario de la cabecera del HTTP
Certificado digital de validación extendida
Códigos QR
Contraseña de un solo uso
Desencriptación por fuerza bruta
Encriptación asimétrica / simétrica
HTTP(S)
Métodos de puerta trasera (*Backdoor methods*)
M-PESA
NFC
Número de autenticación de transacción (TAN)
Phishing
Pingit
Repositorio de descripción de dispositivos (DDR)
Sistema Global para comunicación Móvil (GSM)
SMS
SSL/TLS
STK (*SIM Application Toolkit*, Herramientas de aplicación SIM)
Tecnología *push / pull*
Tecnología sin contactos
Troyano
Troyano MitB (*Man-in-the-Browser*, Hombre en el navegador)
Verificación externa
WEP
WPA
Zapp

Algunas compañías, productos o personas nombrados en este estudio de caso son ficticios y cualquier parecido con entidades reales es mera coincidencia.
